

TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN - ĐẠI HỌC QUỐC GIA TP HCM
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO ĐỒ ÁN - PHÂN HỆ 1 + 2

Môn học:	An toàn và bảo mật dữ liệu trong hệ thống thông tin	
Mã môn học:	CSC12001	
Giảng viên:	Phạm Thị Bạch Huệ Tiết Gia Hồng Lương Vĩ Minh	
Sinh viên thực hiện:	23127036	Bùi Đỗ Hải Đăng
	23127182	Nguyễn Trường Duy
	23127192	Nguyễn Văn Hợp
	23127328	Nguyễn Quốc Bảo
	23127498	Nguyễn Trọng Tín

MỤC LỤC

DANH SÁCH CHỨC NĂNG ĐÃ HOÀN TẤT	3
PHÂN CÔNG THÀNH VIÊN	4
I. PHÂN HỆ 1 - DÀNH CHO NGƯỜI QUẢN TRỊ CƠ SỞ DỮ LIỆU	6
1. Quản lý user/role	6
2. Cấp quyền cho user/role - Cấp role cho user	8
3. Cấp quyền trên các đối tượng của CSDL	9
4. Thu hồi quyền từ user hoặc role	10
5. Xem thông tin về quyền của mỗi user hoặc role trên đối tượng dữ liệu	11
II. PHÂN HỆ 2 - CÀI ĐẶT CHÍNH SÁCH BẢO MẬT CHO HỆ THỐNG BỆNH VIỆN	13
1. Kích bản cài đặt các chính sách - Giải pháp cấp quyền truy cập	13
2. Cơ chế phát tán thông báo dùng OLS	16
2.1. Tổng quan về Oracle Label Security(OLS)	16
2.1.1. Cấu trúc nhãn OLS	16
2.1.2. Quy tắc đọc dữ liệu trong OLS (READ_CONTROL)	16
2.2. Yêu cầu bài toán	16
2.2.1. Mô hình phân cấp	17
2.2.2. Yêu cầu người dùng và dữ liệu	17
2.3 Cài đặt hệ thống OLS	18
2.3.1 Tổng quan quy trình	18
2.3.2 Bước 1 – Reset và cấp quyền (SYS)	18
2.3.3. Bước 2 – Tạo bảng và policy (ADMIN)	19
2.3.4. Bước 3 – Tạo thành phần nhãn (ADMIN – sau reconnect)	19
2.3.5. Bước 4 – Nạp dữ liệu và gán nhãn (ADMIN)	20
2.4. Kiểm tra và đánh giá kết quả	24
2.4.1. Phân tích logic kiểm soát truy cập	24
2.4.2. Câu lệnh kiểm tra	25
2.4.3. Nhận xét đặc biệt về một số trường hợp	25
3. Cơ chế kiểm toán	26
3.1. Giới thiệu về cơ chế kiểm toán	26
3.2. Yêu cầu bài toán	26
3.3. Cách cài đặt	26
4. Sao lưu và phục hồi dữ liệu	29

DANH SÁCH CHỨC NĂNG ĐÃ HOÀN TẤT

STT	Nội dung	Trạng thái (%)
1	Phân hệ 1: Dành cho quản trị viên và giao diện	100
2	Phân hệ 2: Vận dụng các cơ chế bảo mật	100
	Yêu cầu 1	100
	Yêu cầu 2	100
	Yêu cầu 3	100
	Yêu cầu 4	100

PHÂN CÔNG THÀNH VIÊN

MSSV	Họ và tên	Công việc	Phân hệ	Đóng góp (%)
23127036	Bùi Đỗ Hải Đăng	Cho phép thu hồi quyền từ user/role	1	20
		Cho phép xem thông tin về quyền của mỗi user/role trên các đối tượng dữ liệu		
		Cài đặt cơ chế kiểm toán cho hệ thống	2	
		Cài đặt giao diện kiểm toán		
		Cài đặt chức năng sao lưu và khôi phục dữ liệu cho hệ thống.		
23127182	Nguyễn Trường Duy	Setup kết nối Oracle	1	20
		Bootstrap database (Tạo CSDL và insert dữ liệu)		
		Kết nối Winforms, login/test connection		
		Ép thỏa các chính sách bảo mật liên quan đến vai trò “Kỹ thuật viên” và “Bệnh nhân”	2	
		Cài đặt giao diện cho “Kỹ thuật viên” và “Bệnh nhân”		
23127192	Nguyễn Văn Hộp	Grant system/object/role WITH GRANT OPTION	1	20
		Grant mức cột (SELECT, UPDATE)		
		Ép thỏa các chính sách bảo mật liên quan đến vai trò “Điều phối viên” và “Bác sĩ”	2	
		Cài đặt giao diện cho “Điều phối viên” và “Bác sĩ”		
23127328	Nguyễn Quốc Bảo	Quản lý User - Cho phép tạo mới, xóa, sửa (hiệu chỉnh) user hoặc role.	1	20
		Cài đặt cơ chế phát tán thông báo dùng OLS	2	

		Cài đặt giao diện cho phát tán thông báo		
23127498	Nguyễn Trọng Tín	Quản lý User/Role (lock/unlock, list, filter)	1	20
		Cài đặt cơ sở dữ liệu	2	
		Thiết lập tài khoản cho hệ thống theo mô tả TC#1		
Cả nhóm		Viết báo cáo	1 + 2	100
		Quay video demo		

I. PHÂN HỆ 1 - DÀNH CHO NGƯỜI QUẢN TRỊ CƠ SỞ DỮ LIỆU

1. Quản lý user/role

Chức năng quản lý user/role được triển khai trong tab Users và Roles. Quản trị viên có thể xem danh sách user, tìm kiếm user theo từ khóa, tạo user mới, đổi mật khẩu, thay đổi default tablespace, temporary tablespace, profile, khóa/mở khóa tài khoản và xóa user. Với role, ứng dụng hỗ trợ xem danh sách role, tạo role, đổi mật khẩu role và xóa role.

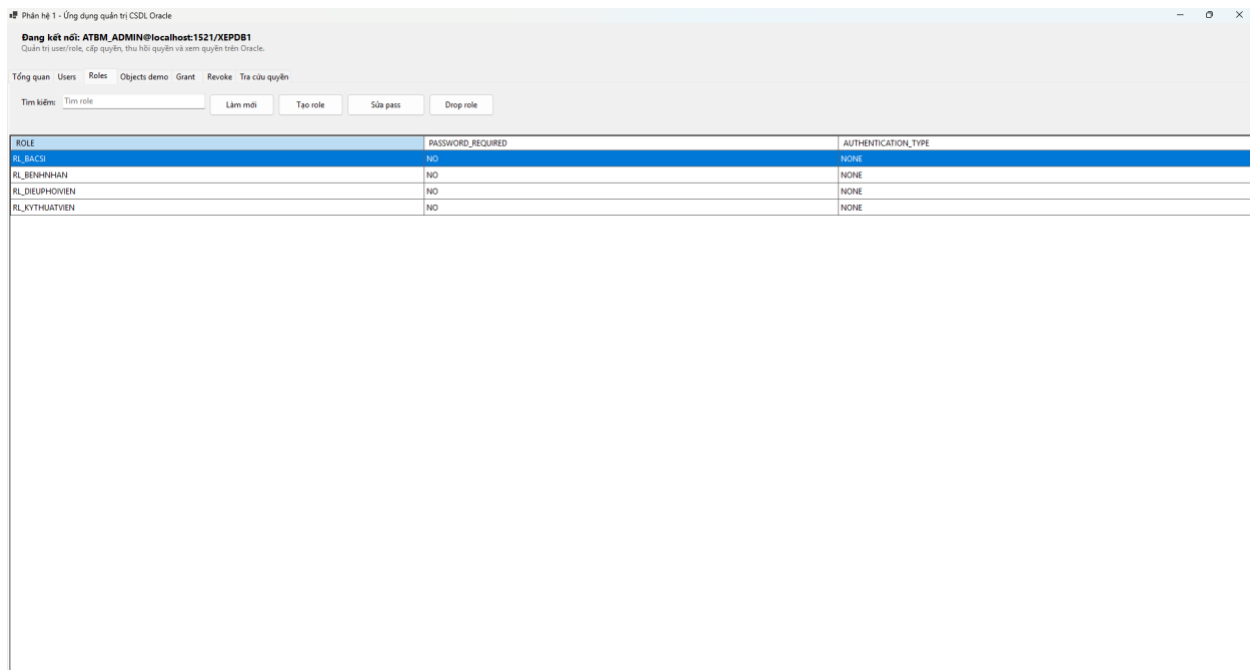
Phân hệ 1 - Ứng dụng quản trị CSDL Oracle

Đang kết nối: ATBM_ADMIN@localhost:1521/XEPDB1
Quản trị user/role, cấp quyền, thu hồi quyền và xem quyền trên Oracle.

Tổng quan Users Roles Objects demo Grant Revoke Tra cứu quyền

Tìm kiếm:

USERNAME	ACCOUNT STATUS	CREATED	DEFAULT_TABLESPACE	TEMPORARY_TABLESPACE	PROFILE
BM000001	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000002	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000003	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000004	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000005	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000006	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000007	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000008	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000009	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000010	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000011	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000012	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000013	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000014	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000015	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000016	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000017	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000018	OPEN	5/4/2026 5:16 PM	SYSTEM	TEMP	DEFAULT
BM000019	OPEN	5/5/2026 4:04 AM	SYSTEM	TEMP	DEFAULT
BM000020	OPEN	5/5/2026 4:04 AM	SYSTEM	TEMP	DEFAULT
NV0001	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0002	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0003	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0004	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0005	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0006	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0007	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0008	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0009	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0010	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0011	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT
NV0012	OPEN	5/4/2026 5:15 PM	SYSTEM	TEMP	DEFAULT



Ở tầng CSDL, các thao tác này được đóng gói trong package PKG_ADMIN, gồm các procedure như:

- SP_CREATE_USER: tạo user với mật khẩu, default tablespace, temporary tablespace và quota.
- SP_ALTER_USER_PASSWORD: đổi mật khẩu user.
- SP_ALTER_USER_DEFAULT_TS, SP_ALTER_USER_TEMP_TS, SP_ALTER_USER_PROFILE: cập nhật thông tin cấu hình user.
- SP_LOCK_USER: khóa hoặc mở khóa user.
- SP_DROP_USER: xóa user, có tùy chọn cascade.
- SP_CREATE_ROLE, SP_ALTER_ROLE_PASSWORD, SP_DROP_ROLE: quản lý role.

Ứng dụng này sẽ được quản trị bởi một tài khoản admin là ATBM_ADMIN:

```
CREATE USER ATBM_ADMIN IDENTIFIED BY "Admin#12345"
DEFAULT TABLESPACE USERS
TEMPORARY TABLESPACE TEMP
QUOTA UNLIMITED ON USERS;

GRANT CREATE SESSION TO ATBM_ADMIN;
GRANT DBA TO ATBM_ADMIN;
GRANT SELECT ANY DICTIONARY TO ATVM_ADMIN;
GRANT CREATE PROCEDURE TO ATBM_ADMIN;
GRANT EXECUTE ON DBMS_RLS TO ATBM_ADMIN;
```

Sử dụng các câu lệnh sau đây để thực hiện các chức năng trên:

- Xem danh sách user hiện có:

```
SELECT USERNAME, ACCOUNT_STATUS, DEFAULT_TABLESPACE,  
TEMPORARY_TABLESPACE, CREATED  
FROM DBA_USERS  
ORDER BY USERNAME;
```

- Xem danh sách role hiện có:

```
SELECT ROLE, PASSWORD_REQUIRED, AUTHENTICATION_TYPE  
FROM DBA_ROLES  
ORDER BY ROLE;
```

- Tạo user:

```
CREATE USER username IDENTIFIED BY password  
DEFAULT TABLESPACE USERS  
TEMPORARY TABLESPACE TEMP  
QUOTA UNLIMITED ON USERS;
```

- Cập nhật user (password):

```
ALTER USER username IDENTIFIED BY new_password;
```

- Khóa/Mở khóa user:

```
ALTER USER username ACCOUNT LOCK;  
ALTER USER username ACCOUNT UNLOCK;
```

- Xóa user:

```
DROP USER username CASCADE;
```

- Tạo role:

```
CREATE ROLE role_name;
```

- Cập nhật role (password):

```
ALTER ROLE role_name IDENTIFIED BY role_password;
```

- Xóa role:

```
DROP ROLE role_name;
```

2. Cấp quyền cho user/role - Cấp role cho user

Ứng dụng cung cấp tab Grant để thực hiện cấp quyền. Quản trị viên chọn đối tượng nhận quyền là USER hoặc ROLE, sau đó chọn một trong ba chế độ:

- Cấp system privilege, ví dụ CREATE SESSION, CREATE TABLE, CREATE VIEW, CREATE PROCEDURE, CREATE ROLE, ALTER USER, DROP USER.

- Cấp object privilege trên table, view, procedure hoặc function.
- Cấp role cho user hoặc role khác.

Tăng database xử lý qua các procedure:

- SP_GRANT_SYSTEM_PRIV: cấp system privilege cho user/role.
- SP_GRANT_ROLE: cấp role cho user/role.
- SP_GRANT_OBJECT_PRIV: cấp quyền trên object, có hỗ trợ WITH GRANT OPTION đối với object privilege.

Khi cấp quyền object, giao diện cho phép chọn owner, object name, object type và privilege tương ứng. Với table/view, ứng dụng cho phép chọn danh sách cột khi cấp quyền SELECT hoặc UPDATE. Riêng UPDATE mức cột được Oracle hỗ trợ trực tiếp bằng cú pháp GRANT UPDATE (col1, col2) ON object TO principal.

Sử dụng các câu lệnh sau đây để thực hiện các chức năng cấp quyền trên:

Cấp quyền hệ thống cho user/role:

```
GRANT system_privilege TO username;
GRANT system_privilege TO role_name;
GRANT system_privilege TO username WITH ADMIN OPTION;
```

Cấp role cho user:

```
GRANT role_name TO username;
GRANT role_name TO username WITH ADMIN OPTION;
```

Cấp quyền trên bảng/view:

```
GRANT SELECT ON owner.table_name TO username;
GRANT INSERT, UPDATE, DELETE ON owner.table_name TO role_name;
GRANT SELECT ON owner.view_name TO role_name;
```

Cấp quyền thực thi procedure/function:

```
GRANT EXECUTE ON owner.procedure_name TO username;
GRANT EXECUTE ON owner.function_name TO role_name;
```

3. Cấp quyền trên các đối tượng của CSDL

Cấp quyền trên đối tượng CSDL được triển khai cho các loại object:

- TABLE và VIEW: hỗ trợ SELECT, INSERT, UPDATE, DELETE.
- PROCEDURE và FUNCTION: hỗ trợ EXECUTE.

Đối với quyền SELECT mức cột, Oracle không hỗ trợ trực tiếp cú pháp GRANT SELECT (column) như UPDATE. Vì vậy nhóm đã triển khai giải pháp bổ sung bằng VPD động trong package PKG_ADMIN. Khi quản trị viên chọn cấp SELECT trên một số cột, hệ thống:

1. Cấp SELECT trên toàn object cho principal.
2. Tạo function VPD tương ứng với principal và object.
3. Gắn policy bằng DBMS_RLS.ADD_POLICY để ẩn các cột không được chọn.
4. Lưu thông tin cấu hình vào bảng APP_VPD_COL_GRANTS.

Các câu lệnh SQL chính dùng để cấp quyền trên đối tượng CSDL:

Cấp quyền cập nhật theo cột:

```
GRANT UPDATE (column_name) ON owner.table_name TO username;  
GRANT UPDATE (column_1, column_2) ON owner.view_name TO  
role_name;
```

Cấp quyền object kèm quyền cấp tiếp:

```
GRANT SELECT ON owner.table_name TO username WITH GRANT OPTION;  
GRANT EXECUTE ON owner.procedure_name TO username WITH GRANT  
OPTION;
```

4. Thu hồi quyền từ user hoặc role

Tab Revoke hỗ trợ thu hồi các loại quyền đã cấp:

- Thu hồi system privilege bằng SP_REVOKE_SYSTEM_PRIV.
- Thu hồi role bằng SP_REVOKE_ROLE.
- Thu hồi object privilege bằng SP_REVOKE_OBJECT_PRIV.

Với object privilege thông thường, package sinh câu lệnh REVOKE privilege ON object FROM principal. Với quyền UPDATE mức cột, do Oracle không hỗ trợ thu hồi riêng từng cột sau khi đã grant theo cột, hệ thống thu hồi quyền UPDATE trên toàn object. Với quyền SELECT mức cột được mô phỏng bằng VPD, hệ thống xóa policy, drop function VPD tương ứng, revoke SELECT trên object và xóa cấu hình khỏi bảng APP_VPD_COL_GRANTS.

Các câu lệnh SQL chính dùng để thu hồi quyền:

Thu hồi quyền hệ thống:

```
REVOKE system_privilege FROM username;  
REVOKE system_privilege FROM role_name;
```

Thu hồi role:

```
REVOKE role_name FROM username;
```

Thu hồi quyền trên object:

```
REVOKE SELECT ON owner.table_name FROM username;
REVOKE INSERT, UPDATE, DELETE ON owner.table_name FROM
role_name;
REVOKE EXECUTE ON owner.procedure_name FROM username;
```

Gỡ policy VPD khi thu hồi quyền SELECT mức cột:

```
BEGIN
    DBMS_RLS.DROP_POLICY (
        object_schema => 'OWNER',
        object_name    => 'TABLE_NAME',
        policy_name    => 'POLICY_NAME'
    );
END;
/
```

5. Xem thông tin về quyền của mỗi user hoặc role trên đối tượng dữ liệu

Ứng dụng có tab Tra cứu quyền để xem tổng hợp quyền của một user hoặc role. Sau khi chọn principal, hệ thống hiển thị các nhóm thông tin:

- System privileges.
- Role grants.
- Object privileges.
- Column privileges.

Các procedure hỗ trợ gồm:

- SP_GET_PRINCIPAL_SYS_PRIVS.
- SP_GET_PRINCIPAL_ROLE_GRANTS.
- SP_GET_PRINCIPAL_OBJ_PRIVS.
- SP_GET_PRINCIPAL_COL_PRIVS.
- SP_GET_PRINCIPAL_SELECT_COL_GRANTS.

Khi tra cứu, hệ thống không chỉ lấy quyền được cấp trực tiếp mà còn xét quyền đi qua role. Nhờ đó quản trị viên có thể kiểm tra đầy đủ một user/role đang có quyền gì, quyền đó đến từ đâu và có được phép cấp tiếp hay không.

Xem quyền hệ thống:

```
SELECT GRANTEE, PRIVILEGE, ADMIN_OPTION
FROM DBA_SYS_PRIVS
WHERE GRANTEE = 'USERNAME_OR_ROLE';
```

Xem role được cấp:

```
SELECT GRANTEE, GRANTED_ROLE, ADMIN_OPTION  
FROM DBA_ROLE_PRIVS  
WHERE GRANTEE = 'USERNAME_OR_ROLE';
```

Xem quyền trên object:

```
SELECT GRANTEE, OWNER, TABLE_NAME, PRIVILEGE, GRANTABLE  
FROM DBA_TAB_PRIVS  
WHERE GRANTEE = 'USERNAME_OR_ROLE';
```

Xem quyền theo cột:

```
SELECT GRANTEE, OWNER, TABLE_NAME, COLUMN_NAME, PRIVILEGE,  
GRANTABLE  
FROM DBA_COL_PRIVS  
WHERE GRANTEE = 'USERNAME_OR_ROLE';
```

II. PHÂN HỆ 2 - CÀI ĐẶT CHÍNH SÁCH BẢO MẬT CHO HỆ THỐNG BỆNH VIỆN

1. Kịch bản cài đặt các chính sách - Giải pháp cấp quyền truy cập

Nhóm sử dụng kết hợp ba lớp bảo vệ:

Thứ nhất, RBAC dùng để phân quyền theo vai trò. Hệ thống tạo bốn role chính:

- **RL_DIEUPHOIVIEN:** điều phối viên.
- **RL_BACSI:** bác sĩ/y sĩ.
- **RL_KYTHUATVIEN:** kỹ thuật viên.
- **RL_BENHNHAN:** bệnh nhân.

TC#1 được nhóm cài đặt bằng cách sử dụng chính tài khoản Oracle làm định danh người dùng trong hệ thống. Không tạo bảng riêng để quản lý tài khoản, mà tạo Oracle user có tên trùng với khóa chính của dòng dữ liệu tương ứng: user nhân viên trùng **NHAN_VIEN.MA_NV** như NV0001, NV0021, NV0121; user bệnh nhân trùng **BENH_NHAN.MA_BN** như BN000001.

Khi người dùng đăng nhập, các chính sách bảo mật lấy **SYS_CONTEXT('USERENV', 'SESSION_USER')** để biết tài khoản hiện tại và ánh xạ trực tiếp tới dòng dữ liệu tương ứng trong **NHAN_VIEN** hoặc **BENH_NHAN**. Nhờ đó, hệ thống chỉ cần dùng tên tài khoản Oracle hiện hành để nối với đúng dòng người dùng, không cần truy cập thêm một bảng ánh xạ tài khoản riêng.

Quy ước đặt mã:

- **Bệnh nhân:** mã dạng BNxxxxxx
- **Nhân viên:** mã dạng NVxxxx
 - NV0001 - NV0020 : Điều phối viên
 - NV0021 - NV0120 : Bác sĩ/Y sĩ
 - NV0121 - NV0170: Kỹ thuật viên

Thứ hai, View được dùng để giới hạn phạm vi dữ liệu cho kỹ thuật viên và bệnh nhân. Ví dụ, kỹ thuật viên thao tác qua **V_HSBA_DV_KTV** và chỉ được cập nhật cột **KET_QUA**; bệnh nhân thao tác qua **V_BENH_NHAN_SELF** để xem/cập nhật thông tin cá nhân của chính mình. Các view này lọc theo **SYS_CONTEXT('USERENV', 'SESSION_USER')** và dùng **WITH CHECK OPTION** để ngăn người dùng cập nhật dữ liệu ra ngoài phạm vi được phép.

Thứ ba, VPD dùng để lọc dòng dữ liệu ở các bảng nghiệp vụ chính cho điều phối viên và bác sĩ. Các policy được gắn bằng **DBMS_RLS**, gồm:

- **POL_BN_RLS** trên **BENH_NHAN**.
- **POL_HSBA_RLS** trên **HSBA**.

- POL_HSBA_DV_RLS trên HSBA_DV.
- POL_DON_THUOC_RLS trên DON_THUOC.
- POL_NHANVIEN_SELF trên NHAN_VIEN.

Với bác sĩ, policy giới hạn dữ liệu theo hồ sơ bệnh án do bác sĩ phụ trách. Với điều phối viên, hệ thống cho phép xem và điều phối theo phạm vi nghiệp vụ đã định. Các policy có bật `update_check = TRUE` để ngăn thao tác INSERT/UPDATE tạo ra dữ liệu không còn thỏa điều kiện truy cập.

Nhóm / cơ chế	Role / policy	Đối tượng dữ liệu	Quyền hoặc phạm vi được phép	Cách kiểm soát
Điều phối viên	RL_DIEUPHOIV IEN	BENH_NHAN, HSBA, HSBA_DV, NHAN_VIEN, MV_BACSI_LIST , MV_KTV_LIST	Xem/thêm bệnh nhân; tạo hồ sơ bệnh án; cập nhật MA_KHOA, MA_BS; phân công MA_KTV; cập nhật thông tin liên hệ của chính mình	RBAC cấp quyền theo bảng/cột; VPD hỗ trợ kiểm soát dòng trên bảng nghiệp vụ
Bác sĩ/Y sĩ	RL_BACSI	HSBA, HSBA_DV, BENH_NHAN, DON_THUOC, NHAN_VIEN, MV_KTV_LIST	Xem hồ sơ của mình; cập nhật CHUAN_DOAN, DIEU_TRI, KET_LUAN; chỉ định/hủy dịch vụ; kê đơn; cập nhật tiền sử bệnh và dị ứng thuốc	RBAC cấp quyền thao tác; VPD lọc dòng theo hồ sơ do bác sĩ phụ trách
Kỹ thuật viên	RL_KYTHUATVI EN	V_HSBA_DV_KTV , V_NHAN_VIEN_SELF	Xem dịch vụ được phân công; chỉ cập nhật KET_QUA; cập nhật QUE_QUAN, SDT của chính mình	Không grant base table; dùng view lọc theo SYS_CONTEXT ('USERENV', 'SESSION_USER') và WITH CHECK OPTION
Bệnh nhân	RL_BENHNHAN	V_BENH_NHAN_SELF	Xem thông tin cá nhân; cập nhật địa chỉ, tiền sử bệnh, tiền sử bệnh gia đình, dị ứng thuốc	Không grant base table; dùng view lọc theo MA_BN = SESSION_USE

				R và WITH CHECK OPTION
VPD trên bệnh nhân	POL_BN _RLS, FN_POL ICY_BE NHNHAN	BENH_NHAN	Điều phối viên thấy dữ liệu phục vụ điều phối; bác sĩ chỉ thấy bệnh nhân thuộc hồ sơ của mình; bệnh nhân đi qua view tự thân	DBMS_RLS.ADD POLICY, bật update_chec k = TRUE
VPD trên hồ sơ bệnh án	POL_HS BA_RLS, FN_POL ICY_HS BA	HSBA	Điều phối viên thấy hồ sơ để điều phối; bác sĩ chỉ thấy hồ sơ có MA_BS = SESSION_USER; KTV/BN không có quyền base table	DBMS_RLS.ADD POLICY, bật update_chec k = TRUE
VPD trên dịch vụ	POL_HS BA_DV_ RLS, FN_POL ICY_HS BA_DV	HSBA_DV	Điều phối viên thấy dịch vụ để phân công; bác sĩ thấy dịch vụ thuộc hồ sơ của mình; KTV đi qua V_HSBA_DV_KTV	RBAC quyết định quyền thao tác, VPD lọc dòng cho nhóm truy cập base table
VPD trên đơn thuốc	POL_DO N_THUO C_RLS, FN_POL ICY_DO N_THUO C	DON_THUOC	Bác sĩ thấy và thao tác đơn thuốc thuộc hồ sơ của mình; các nhóm khác không truy cập	VPD lọc theo hồ sơ bệnh án liên quan bác sĩ
VPD trên nhân viên	POL_NH ANVIEN _SELF, FN_POL ICY_NH ANVIEN	NHAN_VIEN	Nhân viên chỉ thấy/cập nhật một phần thông tin của chính mình; danh sách bác sĩ/KTV lấy qua materialized view riêng	VPD self-scope trên NHAN_VIEN; dùng MV_BACSI_LI ST, MV_KTV_LIST để phục vụ dropdown

2. Cơ chế phát tán thông báo dùng OLS

2.1. Tổng quan về Oracle Label Security(OLS)

Oracle Label Security (OLS) là cơ chế bảo mật cấp hàng (row-level security) tích hợp sẵn trong Oracle Database. OLS kiểm soát việc người dùng nào có thể đọc hoặc ghi dòng dữ liệu nào bằng cách gắn nhãn (label) cho từng dòng dữ liệu và so sánh với nhãn của người dùng khi truy vấn.

Không giống với GRANT/REVOKE thông thường chỉ kiểm soát quyền ở cấp bảng hoặc cột, OLS lọc dữ liệu tự động tại tầng kernel trước khi kết quả trả về cho người dùng, hoàn toàn trong suốt với tầng ứng dụng.

2.1.1. Cấu trúc nhãn OLS

Mỗi nhãn OLS có cấu trúc gồm tối đa 3 thành phần:

- Level (cấp độ bảo mật): là thành phần bắt buộc, xác định cấp bậc truy cập theo thứ tự phân cấp (số càng cao = cấp càng cao). Người dùng chỉ đọc được dòng có $\text{level} \leq \text{level}$ của mình.
- Compartment (phòng ban/chuyên môn): là thành phần tùy chọn, xác định nhóm chuyên môn. Người dùng phải có tất cả các compartment mà dòng dữ liệu yêu cầu.
- Group (nhóm địa lý/tổ chức): là thành phần tùy chọn, xác định địa điểm hoặc đơn vị. Người dùng cần giao nhau ít nhất một group với dòng dữ liệu.

Cú pháp biểu diễn nhãn:

LEVEL[:COMPARTMENT1,COMPARTMENT2,...[:GROUP1,GROUP2,...]]

2.1.2. Quy tắc đọc dữ liệu trong OLS (READ_CONTROL)

Người dùng U đọc được dòng dữ liệu D khi và chỉ khi thỏa đồng thời 3 điều kiện:

- Điều kiện Level: $\text{level}(U) \geq \text{level}(D)$
- Điều kiện Compartment: $\text{compartments}(U) \supseteq \text{compartments}(D)$ (tập của user phải chứa tập của dữ liệu)
- Điều kiện Group: $\text{groups}(U) \cap \text{groups}(D) \neq \emptyset$, hoặc dữ liệu không có group

2.2. Yêu cầu bài toán

Bệnh viện X cần phát tán thông báo về các cuộc họp khẩn đến đúng đối tượng theo cấp bậc, khoa chuyên môn và cơ sở địa lý, sử dụng cơ chế OLS trên bảng THONGBAO gồm các trường NOIDUNG, NGAYGIO, DIADIEM.

2.2.1. Mô hình phân cấp

Hệ thống phân chia theo 3 chiều độc lập:

Thành phần OLS	Các giá trị	Ý nghĩa
Level	BGD (3000) > LDK (2000) > NV (1000)	Cấp bậc chức vụ trong bệnh viện
Compartment	TH (10), TK (20), TM (30)	Khoa chuyên môn: Tiêu hóa, Thần kinh, Tim mạch
Group	HCM (100), HP (200), HN (300)	Cơ sở: Hồ Chí Minh, Hải Phòng, Hà Nội

2.2.2. Yêu cầu người dùng và dữ liệu

ID	User	Mô tả	Nhãn gán
u1	NV0001	Giám đốc – đọc được toàn bộ thông báo	BGD:TH,TK,TM:HCM,HP,HN
u2	NV0021	Lãnh đạo Khoa Tim mạch tại Hồ Chí Minh	LDK:TM:HCM
u3	NV0022	Lãnh đạo Khoa Thần kinh tại Hà Nội	LDK:TK:HN
u4	NV0121	Nhân viên Khoa Thần kinh tại Hồ Chí Minh	NV:TK:HCM
u5	NV0122	Nhân viên Khoa Tim mạch tại Hồ Chí Minh	NV:TM:HCM
u6	NV0002	Lãnh đạo phòng – đọc TB Khoa Tim mạch tại HCM	LDK:TM:HCM
u7	NV0003	Lãnh đạo phòng – đọc toàn bộ thông báo cấp LDK	LDK:TH,TK,TM:HCM,HP,HN
u8	NV0123	Nhân viên Khoa Tiêu hóa tại Hà Nội	NV:TH:HN

ID	Mã TB	Mô tả nội dung	Nhãn dữ liệu
----	-------	----------------	--------------

t1	T1	Gửi đến toàn thể nhân viên bệnh viện	NV
t2	T2	Gửi đến toàn bộ Ban giám đốc	BGD
t3	T3	Gửi đến các lãnh đạo khoa	LDK
t4	T4	Gửi đến lãnh đạo Khoa Tiêu hóa	LDK:TH
t5	T5	Gửi đến nhân viên Khoa Tiêu hóa tại HCM	NV:TH:HCM
t6	T6	Gửi đến nhân viên Khoa Tiêu hóa tại Hà Nội	NV:TH:HN
t7	T7	Gửi đến lãnh đạo Khoa Tiêu hóa và Thần kinh tại Hải Phòng	LDK:TH,TK:HP

2.3 Cài đặt hệ thống OLS

2.3.1 Tổng quan quy trình

Toàn bộ quy trình thiết lập OLS gồm 5 bước chính, thực hiện qua 5 file SQL tương ứng:

- 00_reset_ols.sql – Reset toàn bộ policy cũ (chạy với SYS)
- 01_sys_setup.sql – Cấp quyền OLS cho tài khoản ADMIN (chạy với SYS)
- 02_admin_table_policy.sql – Tạo bảng THONGBAO và policy REGION_POLICY (chạy với ADMIN)
- 03_admin_policy_components.sql – Định nghĩa Level, Compartment, Group và Label (chạy với ADMIN sau khi reconnect)
- 04_admin_data_apply.sql – Insert dữ liệu, gán nhãn dữ liệu và nhãn người dùng (chạy với ADMIN)

2.3.2 Bước 1 – Reset và cấp quyền (SYS)

File 00_reset_ols.sql dọn sạch policy cũ trước khi thiết lập lại, gồm 3 thao tác tuần tự:

```
SA_POLICY_ADMIN.REMOVE_TABLE_POLICY('REGION_POLICY', 'ADMIN',
'THONGBAO');
SA_SYSDBA.DISABLE_POLICY('REGION_POLICY');
SA_SYSDBA.DROP_POLICY(POLICY_NAME => 'REGION_POLICY',
DROP_COLUMN => TRUE);
```

File 01_sys_setup.sql cấp các quyền OLS cần thiết cho ADMIN để có thể gọi các package SA_* trong các bước tiếp theo:

```
GRANT EXECUTE ON LBACSYS.SA_COMPONENTS TO ADMIN WITH GRANT
OPTION;
GRANT EXECUTE ON LBACSYS.SA_USER_ADMIN TO ADMIN WITH GRANT
OPTION;
GRANT EXECUTE ON SA_POLICY_ADMIN TO ADMIN WITH GRANT OPTION;
GRANT LBAC_DBA TO ADMIN;
```

2.3.3. Bước 2 – Tạo bảng và policy (ADMIN)

File 02_admin_table_policy.sql thực hiện:

- Tạo bảng THONGBAO với các trường MA_TB, NOI_DUNG, NGAY_GIO, DIA_DIEM
- Cấp quyền SELECT trên bảng THONGBAO cho 8 user test
- Tạo policy REGION_POLICY với cột nhãn REGION_LABEL

```
SA_SYSDBA.CREATE_POLICY(POLICY_NAME => 'REGION_POLICY',
COLUMN_NAME => 'REGION_LABEL');
EXEC SA_SYSDBA.ENABLE_POLICY('REGION_POLICY');
```

Lưu ý quan trọng: Sau khi chạy file này, bắt buộc phải DISCONNECT rồi CONNECT lại ADMIN. Nếu không, Oracle sẽ báo lỗi ORA-12407 hoặc ORA-12446 do policy chưa được nhận diện trong phiên làm việc hiện tại.

2.3.4. Bước 3 – Tạo thành phần nhãn (ADMIN – sau reconnect)

File 03_admin_policy_components.sql định nghĩa đầy đủ 3 thành phần của hệ thống nhãn:

Tạo Level (cấp độ phân cấp)

```
BEGIN
    SA_COMPONENTS.CREATE_LEVEL('REGION_POLICY', 1000, 'NV',
    'Nhan vien');
    SA_COMPONENTS.CREATE_LEVEL('REGION_POLICY', 2000, 'LDK',
    'Lanh dao khoa');
    SA_COMPONENTS.CREATE_LEVEL('REGION_POLICY', 3000, 'BGD',
    'Ban giam doc');
END;
/
```

Giá trị số càng lớn thì cấp độ càng cao. BGD (3000) > LDK (2000) > NV (1000).

Tạo Compartment (khoa chuyên môn)

```
BEGIN
    SA_COMPONENTS.CREATE_COMPARTMENT('REGION_POLICY', 10,
    'TH', 'Tieu hoa');
```

```

        SA_COMPONENTS.CREATE_COMPARTMENT('REGION_POLICY', 20,
'TK', 'Than kinh');
        SA_COMPONENTS.CREATE_COMPARTMENT('REGION_POLICY', 30,
'TM', 'Tim mach');
END;
/

```

Tạo Group (cơ sở địa lý)

```

BEGIN
        SA_COMPONENTS.CREATE_GROUP('REGION_POLICY', 100, 'HCM',
'Ho Chi Minh');
        SA_COMPONENTS.CREATE_GROUP('REGION_POLICY', 200, 'HP',
'Hai Phong');
        SA_COMPONENTS.CREATE_GROUP('REGION_POLICY', 300, 'HN',
'Ha Noi');
END;
/

```

Tạo Label (tổ hợp các thành phần)

Các nhãn được tạo để phục vụ gán cho dữ liệu:

```

BEGIN
        SA_LABEL_ADMIN.CREATE_LABEL('REGION_POLICY', 1001, 'NV');
        SA_LABEL_ADMIN.CREATE_LABEL('REGION_POLICY', 1002, 'BGD');
        SA_LABEL_ADMIN.CREATE_LABEL('REGION_POLICY', 1003, 'LDK');
        SA_LABEL_ADMIN.CREATE_LABEL('REGION_POLICY', 1004,
'LDK:TH');
        SA_LABEL_ADMIN.CREATE_LABEL('REGION_POLICY', 1005,
'NV:TH:HCM');
        SA_LABEL_ADMIN.CREATE_LABEL('REGION_POLICY', 1006,
'NV:TH:HN');
        SA_LABEL_ADMIN.CREATE_LABEL('REGION_POLICY', 1007,
'LDK:TH,TK:HP');
END;
/

```

2.3.5. Bước 4 – Nạp dữ liệu và gán nhãn (ADMIN)

File 04_admin_data_apply.sql thực hiện theo trình tự sau:

Apply policy với NO_CONTROL để insert dữ liệu tự do

Trước tiên, policy được áp dụng ở chế độ NO_CONTROL để có thể INSERT dữ liệu mà không bị lọc. Đây là kỹ thuật bắt buộc khi dữ liệu chưa có nhãn:

```

BEGIN

```

```

        SA_POLICY_ADMIN.APPLY_TABLE_POLICY (
            POLICY_NAME      => 'REGION_POLICY',
            SCHEMA_NAME      => 'ADMIN',
            TABLE_NAME      => 'THONGBAO',
            TABLE_OPTIONS  => 'NO_CONTROL'
        );
END;
/

```

Insert 7 bản ghi thông báo

7 bản ghi được insert vào bảng THONGBAO tương ứng với 7 kịch bản thông báo t1-t7:

```

INSERT INTO THONGBAO VALUES (
    'T1',
    N'Họp khẩn toàn thể nhân viên bệnh viện về quy trình ứng
phó sự cố',
    TIMESTAMP '2025-05-01 08:00:00',
    'Tất cả cơ sở',
    NULL
);

INSERT INTO THONGBAO VALUES (
    'T2',
    N'Họp khẩn Ban giám đốc về kế hoạch điều hành bệnh viện',
    TIMESTAMP '2025-05-01 09:00:00',
    N'Phòng họp Ban giám đốc',
    NULL
);

INSERT INTO THONGBAO VALUES (
    'T3',
    N'Họp khẩn dành cho lãnh đạo các khoa về phối hợp chuyên
môn',
    TIMESTAMP '2025-05-01 10:00:00',
    N'Tất cả cơ sở',
    NULL
);

INSERT INTO THONGBAO VALUES (
    'T4',
    N'Họp khẩn lãnh đạo Khoa Tiêu hóa về phân công nhân sự',
    TIMESTAMP '2025-05-01 11:00:00',

```

```

        N'Khoa Tiêu hóa',
        NULL
    );

INSERT INTO THONGBAO VALUES (
    'T5',
    N'Hợp khẩn nhân viên Khoa Tiêu hóa tại cơ sở Hồ Chí Minh',
    TIMESTAMP '2025-05-01 12:00:00',
    N'Cơ sở Hồ Chí Minh',
    NULL
);

INSERT INTO THONGBAO VALUES (
    'T6',
    N'Hợp khẩn nhân viên Khoa Tiêu hóa tại cơ sở Hà Nội',
    TIMESTAMP '2025-05-01 13:00:00',
    N'Cơ sở Hà Nội',
    NULL
);

INSERT INTO THONGBAO VALUES (
    'T7',
    N'Hợp khẩn lãnh đạo Khoa Tiêu hóa và Khoa Thần kinh tại
    Hải Phòng',
    TIMESTAMP '2025-05-01 14:00:00',
    N'Cơ sở Hải Phòng',
    NULL
);

```

Gán nhãn cho từng dòng dữ liệu

```

UPDATE THONGBAO
SET REGION_LABEL = CHAR_TO_LABEL('REGION_POLICY', 'NV')
WHERE MA_TB = 'T1';

UPDATE THONGBAO
SET REGION_LABEL = CHAR_TO_LABEL('REGION_POLICY', 'BGD')
WHERE MA_TB = 'T2';

UPDATE THONGBAO
SET REGION_LABEL = CHAR_TO_LABEL('REGION_POLICY', 'LDK')
WHERE MA_TB = 'T3';

```

```

UPDATE THONGBAO
SET REGION_LABEL = CHAR_TO_LABEL('REGION_POLICY', 'LDK:TH')
WHERE MA_TB = 'T4';

UPDATE THONGBAO
SET REGION_LABEL = CHAR_TO_LABEL('REGION_POLICY', 'NV:TH:HCM')
WHERE MA_TB = 'T5';

UPDATE THONGBAO
SET REGION_LABEL = CHAR_TO_LABEL('REGION_POLICY', 'NV:TH:HN')
WHERE MA_TB = 'T6';

UPDATE THONGBAO
SET REGION_LABEL = CHAR_TO_LABEL('REGION_POLICY',
'LDK:TH,TK:HP')
WHERE MA_TB = 'T7';

```

Chuyển sang READ_CONTROL

Sau khi dữ liệu đã có nhãn, policy được gỡ ra

```

BEGIN
    SA_POLICY_ADMIN.REMOVE_TABLE_POLICY(
        POLICY_NAME => 'REGION_POLICY',
        SCHEMA_NAME => 'ADMIN',
        TABLE_NAME => 'THONGBAO'
    );
END;
/

```

Sau đó apply lại với READ_CONTROL để kích hoạt lọc dữ liệu tự động theo nhãn:

```

BEGIN
    SA_POLICY_ADMIN.APPLY_TABLE_POLICY(
        POLICY_NAME => 'REGION_POLICY',
        SCHEMA_NAME => 'ADMIN',
        TABLE_NAME => 'THONGBAO',
        TABLE_OPTIONS => 'READ_CONTROL'
    );
END;
/

```

Gán nhãn cho người dùng

```

BEGIN

```

```

SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0001',
'BGD:TH,TK, TM:HCM,HP,HN');
SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0021',
'LDK:TM:HCM');
SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0022',
'LDK:TK:HN');
SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0121',
'NV:TK:HCM');
SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0122',
'NV:TM:HCM');
SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0002',
'LDK:TM:HCM');
SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0003',
'LDK:TH,TK, TM:HCM,HP,HN');
SA_USER_ADMIN.SET_USER_LABELS('REGION_POLICY', 'NV0123',
'NV:TH:HN');
END;
/

```

2.4. Kiểm tra và đánh giá kết quả

2.4.1. Phân tích logic kiểm soát truy cập

Dưới đây là bảng phân tích chi tiết từng user có thể đọc những dòng nào, dựa trên 3 điều kiện OLS:

User	Nhân user	Dòng đọc được	Lý do	Kết quả
NV0001	BGD:TH,TK, TM:HCM,HP ,HN	T1–T7 (7 dòng)	BGD là cấp cao nhất, có đủ mọi compartment và group	Đúng
NV0021	LDK:TM:HCM	T1, T3 (2 dòng)	LDK<BGD nên không đọc T2; thiếu compartment TH nên không đọc T4,T5,T6,T7	Đúng
NV0022	LDK:TK:HN	T1, T3 (2 dòng)	LDK<BGD; thiếu TH cho T4; HP không giao HN cho T7	Đúng
NV0121	NV:TK:HCM	T1 (1 dòng)	NV<LDK<BGD; compartment TK không chứa TH	Đúng
NV0122	NV:TM:HCM	T1 (1 dòng)	NV<LDK; compartment TM không chứa TH	Đúng

NV0002	LDK:TM:HCM	T1, T3 (2 dòng)	Giống NV0021 – cùng nhãn	Đúng
NV0003	LDK:TH,TK,TM:HCM,HP,HN	T1,T3–T7 (6 dòng)	LDK không đọc T2 (BGD), nhưng đọc đủ còn lại	Đúng
NV0123	NV:TH:HN	T1, T6 (2 dòng)	NV<LDK; đọc T6 vì NV≥NV, TH⊇TH, HN∩HN; T5 không đọc vì HN≠HCM	Đúng

2.4.2. Câu lệnh kiểm tra

Để kiểm tra kết quả, đăng nhập bằng từng user và chạy:

```
SELECT MA_TB, NOI_DUNG, DIA_DIEM
FROM ADMIN.THONGBAO
ORDER BY MA_TB;

SELECT COUNT(*) AS SO_DONG_NHIN_THAY
FROM ADMIN.THONGBAO;
```

OLS hoạt động hoàn toàn trong suốt: cùng một câu SELECT, mỗi user nhìn thấy số dòng khác nhau mà không cần sửa query.

2.4.3. Nhận xét đặc biệt về một số trường hợp

Trường hợp NV0001 – Giám đốc

Mặc dù label là BGD nhưng không thể chỉ dùng 'BGD' đơn thuần vì BGD-level sẽ không đọc được các dòng có compartment (TH, TM, TK) hoặc group (HCM, HP, HN) theo quy tắc subset. Do đó phải gán đầy đủ BGD:TH,TK,TM:HCM,HP,HN để Giám đốc đọc được toàn bộ 7 dòng.

Trường hợp NV0003 – Lãnh đạo phòng đọc toàn bộ cấp LDK

NV0003 có nhãn LDK:TH,TK,TM:HCM,HP,HN nên đọc được mọi thông báo cấp LDK trở xuống với đủ khoa và cơ sở, nhưng KHÔNG đọc được T2 (BGD) vì LDK < BGD.

Trường hợp T7 – Thông báo nhiều compartment

T7 có nhãn LDK:TH,TK:HP nghĩa là phải có cả compartment TH và TK. Vì vậy NV0022 (LDK:TK:HN) không đọc được T7 dù cùng cấp LDK, vì thiếu compartment TH.

3. Cơ chế kiểm toán

3.1. Giới thiệu về cơ chế kiểm toán

Audit hay cơ chế kiểm toán là một hệ thống các hoạt động kiểm tra, xác nhận và đánh giá tính chính xác, trung thực của các thông tin (thường là dữ liệu số) hoặc việc tuân thủ các quy trình trong một tổ chức. Nó giống như việc bạn có một "người giám sát độc lập" đứng ra soát lại toàn bộ công việc để đảm bảo mọi thứ không có sai sót hoặc gian lận.

Bản chất của Audit: "Audit Trail" với cốt lõi là tạo ra một chuỗi các bản ghi (logs) không thể thay đổi, thường bao gồm:

- Who: Ai là người thực hiện hành động? (User ID, IP Address).
- What: Hành động gì đã xảy ra? (Truy cập, Chính sửa, Xóa, Xuất dữ liệu).
- When: Thời điểm chính xác (Timestamp).
- Where: Thao tác trên bảng dữ liệu hay tệp tin nào?
- Result: Hành động đó thành công hay thất bại? (Ví dụ: Đăng nhập sai nhiều lần).

Mục tiêu của Audit là:

- Tính không thể chối bỏ (Non-repudiation): Đây là mục tiêu quan trọng nhất trong bảo mật. Một khi hành động đã được ghi lại bởi cơ chế Audit, cá nhân thực hiện không thể phủ nhận việc mình đã làm.
- Phát hiện xâm nhập (Intrusion Detection): Audit không chỉ để xem lại quá khứ mà còn để nhận diện các dấu hiệu bất thường trong thời gian thực. Ví dụ: Một tài khoản nhân viên bỗng dưng truy cập vào dữ liệu nhạy cảm vào lúc 2 giờ sáng.
- Phục hồi sau sự cố (Forensics): Khi hệ thống gặp lỗi hoặc bị tấn công, Audit là "hiện trường" để các chuyên gia lần theo dấu vết, xác định phạm vi thiệt hại và tìm cách khắc phục.
- Đảm bảo tính toàn vẹn (Integrity): Kiểm tra xem dữ liệu có bị thay đổi trái phép hay không. Nếu không có Audit, dữ liệu bị sửa đổi sẽ không ai hay biết, dẫn đến sai lệch toàn bộ hệ thống báo cáo.

3.2. Yêu cầu bài toán

Bài toán bao gồm các yêu cầu:

- Kích hoạt hệ thống kiểm toán
- Sử dụng standard audit
- Sử dụng Fine-grained Audit hoặc Unified Audit, đề án này sử dụng Unified Audit
- Đọc và xuất dữ liệu kiểm toán.

3.3. Cách cài đặt

Để cài đặt kiểm toán, cần đảm bảo audit đã được kích hoạt, nên phần 1 yêu cầu kích hoạt kiểm toán.

```
ALTER SYSTEM SET audit_trail=db,extended SCOPE=SPFILE;
```

```
SHUTDOWN IMMEDIATE;  
STARTUP;
```

Tiếp theo, thực hiện audit cho từng ngữ cảnh đã đề ra:

```
AUDIT SELECT ON admin.hsba BY ACCESS;  
AUDIT UPDATE ON admin.don_thuoc BY ACCESS WHENEVER NOT  
SUCCESSFUL;  
AUDIT DELETE ON admin.hsba_dv BY ACCESS WHENEVER SUCCESSFUL;  
AUDIT SESSION BY NV0051;  
AUDIT INSERT ON admin.benh_nhan BY ACCESS WHENEVER SUCCESSFUL;
```

Trên đây là 5 ngữ cảnh đề ra, bao gồm: Chọn trên bảng admin.hsba, thay đổi không thành trên bảng admin.don_thuoc, xóa dữ liệu không thành admin.hsba_dv, kiểm soát hoạt động của user NV0051 và việc thêm bệnh nhân không thành công trên admin.benh_nhan

Tiếp theo là cài đặt thuật toán Unified Audit cho những ngữ cảnh được đề ra:

- Cập nhật trên bảng đơn thuốc

```
CREATE AUDIT POLICY UNIFIED_AUDIT_UPDATE_DONTHUOC  
ACTIONS UPDATE ON admin.don_thuoc;  
AUDIT POLICY UNIFIED_AUDIT_UPDATE_DONTHUOC;
```

- Cập nhật hợp pháp hoặc bất hợp pháp trên bảng hsba:

```
CREATE AUDIT POLICY UNIFIED_AUDIT_ILLEGAL_UPDATE_HSBA  
ACTIONS UPDATE ON admin.hsba;  
AUDIT POLICY UNIFIED_AUDIT_ILLEGAL_UPDATE_HSBA;
```

- Người thêm xóa sửa trong bảng hsba_dv không là admin

```
CREATE AUDIT POLICY UNIFIED_AUDIT_ILLEGAL_DML_HSBA_DV  
ACTIONS INSERT ON admin.hsba_dv,  
UPDATE ON admin.hsba_dv,  
DELETE ON admin.hsba_dv  
WHEN 'SYS_CONTEXT(''USERENV'', 'SESSION_USER') <>  
'ADMIN'''  
EVALUATE PER STATEMENT;  
AUDIT POLICY UNIFIED_AUDIT_ILLEGAL_DML_HSBA_DV;
```

Cuối cùng để hiển thị ra các log được audit ghi lại, chạy lệnh trong file 04_show_log.sql

```
-- Xem toàn bộ dữ liệu Standard Audit liên quan đến các bảng  
và user trong script  
SELECT  
username AS "Tài khoản",  
timestamp AS "Thời gian",
```

```

    obj_name AS "Tên bảng",
    action_name AS "Hành động",
    returncode AS "Mã kết quả (0=Thành công)",
    sql_text AS "Câu lệnh SQL" -- (Nếu có bật audit_trail =
db, extended)
FROM
    dba_audit_trail
WHERE
    -- 1. SELECT trên hsba (Tất cả)
    (obj_name = 'HSBA' AND action_name = 'SELECT')

    -- 2. UPDATE trên don_thuoc (Chỉ khi thất bại: returncode
!= 0)
    OR (obj_name = 'DON_THUOC' AND action_name = 'UPDATE' AND
returncode != 0)

    -- 3. DELETE trên hsba_dv (Chỉ khi thành công: returncode
= 0)
    OR (obj_name = 'HSBA_DV' AND action_name = 'DELETE' AND
returncode = 0)

    -- 4. Audit phiên làm việc của user NV0051
    OR (username = 'NV0051' AND action_name IN ('LOGON',
'LOGOFF'))

    -- 5. INSERT trên benh_nhan (Chỉ khi thành công:
returncode = 0)
    OR (obj_name = 'BENH_NHAN' AND action_name = 'INSERT' AND
returncode = 0)
ORDER BY
    timestamp DESC;

-- Xem dữ liệu từ các Unified Audit Policies đã tạo
SELECT
    dbusername AS "Tài khoản",
    event_timestamp AS "Thời gian",

```

```

    action_name AS "Hành động",
    object_schema AS "Schema",
    object_name AS "Tên bảng",
    unified_audit_policies AS "Tên Policy vi phạm",
    sql_text AS "Câu lệnh SQL đã chạy",
    client_program_name AS "Phần mềm kết nối"
FROM
    unified_audit_trail
WHERE
    unified_audit_policies LIKE
'%UNIFIED_AUDIT_UPDATE_DONTHUOC%'
    OR unified_audit_policies LIKE
'%UNIFIED_AUDIT_ILLEGAL_UPDATE_HSBA%'
    OR unified_audit_policies LIKE
'%UNIFIED_AUDIT_ILLEGAL_DML_HSBA_DV%'
ORDER BY
    event_timestamp DESC;

```

4. Sao lưu và phục hồi dữ liệu

4.1. Phương pháp thực hiện sao lưu và phục hồi dữ liệu

Để tiến hành sao lưu dữ liệu của cơ sở dữ liệu, có 3 phương pháp chính, bao gồm:

- Logical Backup (Sao lưu mức logic): Là phương pháp trích xuất dữ liệu và cấu trúc logic của cơ sở dữ liệu (như Table, View, Stored Procedure, Function...) ra một tệp tin nhị phân độc lập (ví dụ: tệp .dmp). Quá trình này không sao chép trực tiếp các tệp vật lý mà hệ thống sẽ dùng các câu lệnh SQL ngầm để đọc và xuất dữ liệu. Công cụ tiêu chuẩn trong Oracle là Data Pump (expdp/impdp). Phương pháp này rất linh hoạt để chuyển đổi dữ liệu, nhưng có khuyết điểm là tốn nhiều thời gian trích xuất khi cơ sở dữ liệu có kích thước quá lớn.
- Physical Backup (Sao lưu mức vật lý): Đây mới chính là phương pháp sao chép trực tiếp các tệp tin vật lý đang cấu thành nên cơ sở dữ liệu ở cấp độ hệ điều hành (bao gồm Datafiles, Control files, và Archived Redo Logs). Công cụ quản lý tiêu chuẩn là RMAN (Recovery Manager). Ưu điểm cốt lõi của phương pháp này là tốc độ sao lưu và phục hồi cực kỳ nhanh chóng, giúp khôi phục toàn vẹn hệ thống kể cả khi xảy ra thảm họa phần cứng (như hỏng ổ đĩa cứng).
- Flashback Technology (Công nghệ quay lui thời gian): Khác với hai phương pháp trên, Flashback không tạo ra các bản sao lưu để cất giữ ở nơi khác. Thay vào đó, nó tận dụng

vùng không gian đặc biệt (Undo Tablespace) để giữ lại các "bản nháp" của dữ liệu trước khi chúng bị thay đổi. Cơ chế này cho phép "quay ngược thời gian" (Point-in-Time Recovery) một cách tức thời về bất kỳ mốc thời gian cụ thể nào trong quá khứ. Đây là phương pháp hoàn hảo và nhanh nhất để khôi phục dữ liệu khi phát hiện sự cố do con người thao tác sai (thông qua việc đối chiếu với nhật ký kiểm toán).

4.2. Cài đặt

Hệ thống được cài đặt 2 cách để lưu backup:

- **Chủ động:** Admin có thể chủ động lưu backup bằng việc thực thi file 01_logical_backup.sql. Khi này hệ thống sẽ yêu cầu nhập bảng cần backup. Khi đó bảng được nhập sẽ được tạo 1 bản sao trong cơ sở dữ liệu, rồi tiến hành sao lưu bản đó về máy.
- **Tự động:** Hệ thống hiện tại được cài đặt hàm tự động sao lưu dữ liệu của bảng hsba_dv mỗi phút. Để thay đổi bảng được sao lưu và tần suất sao lưu, cần phải truy cập trực tiếp vào file 03_automatic_backup.sql để thay đổi.

Lưu ý: hiện tại khi lưu về thì hệ thống sẽ mặc định đặt file đó trong thư mục 'Data_pump_dir' mặc định của cơ sở dữ liệu. thường có đường dẫn giống như sau:

C:\app\LENOVO\product\21c\admin\xe\dpdump\B03F1C95971D44E1A7CA69EEEE9C0FBA.

Hệ thống hiện tại cũng có 2 phương pháp để khôi phục:

- **Khôi phục thủ công:** Người dùng cần chọn file sao lưu để tiến hành khôi phục cơ sở dữ liệu. File được chọn bằng cách nhập tên của backup và đảm bảo rằng file đó đang nằm trong thư mục 'Data_pump_dir' trên
- **Khôi phục dựa trên kiểm toán (Flashback):** Hệ thống sẽ truy vết về lần gần nhất thay đổi (hiện tại đang kiểm tra trên bảng đơn thuốc, sau đó kiểm tra dữ liệu trước đó 1 phút và nếu tồn tại sẽ tiến hành backup).

4.3. Đánh giá

Tiêu chí	Logical Backup	Flashback
Mục đích chính	Lưu trữ lâu dài, di chuyển dữ liệu.	Sửa lỗi thao tác của người dùng, khôi phục nhanh.
Tốc độ khôi phục	Chậm (tỷ lệ thuận với lượng dữ liệu).	Rất nhanh.

Mức độ khôi phục	Object (Table, Schema, DB).	Giao dịch, Dòng, Bảng, Database.
Khả năng mất dữ liệu	Có (chỉ đến thời điểm backup).	Thấp (nếu nằm trong vùng lưu trữ cho phép).
Phạm vi bảo vệ	Bảo vệ trước hỏng hóc vật lý/logic.	Chỉ bảo vệ trước các lỗi logic (nhầm lẫn dữ liệu).

4.4. Kết luận

Dùng Flashback để xử lý nhanh các lỗi do con người (lỡ tay xóa nhầm, update nhầm) nhằm giảm thiểu thời gian hệ thống ngừng hoạt động.

Dùng Logical Backup để lưu trữ lâu dài, di chuyển dữ liệu giữa các môi trường (từ máy chủ này sang máy chủ khác) hoặc làm sạch phân mảnh dữ liệu.

Lưu ý: Cả hai đều không thể thay thế hoàn toàn Physical Backup (RMAN) trong việc bảo vệ hệ thống trước các thảm họa hỏng hóc phần cứng nặng nề.